

- Designing applications to ensure that critical information, such as passwords and credit card numbers, does not reside directly on a device. If critical information resides directly on a device, it should be stored securely (e.g., within an encrypted data section or within encrypted storage in the file system).
- Establishing processes when implementing mobile applications to collect only necessary information and appropriately secure that information and any related analytics reporting available within or external to the mobile application.
- Designing applications to mitigate the risk of unpatched devices or those that are no longer supported by the manufacturer.
- Securing back-end servers containing the MFS application and customer data to prevent unauthorized users from accessing data. If a third party manages the application and back-end server, validate that the third party implements appropriate security measures.
- Developing applications in a “sandbox,”<sup>27</sup> which creates a more secure area within the device from which to process transactions.
- Maintaining awareness of vulnerabilities through online forums, vendor sites, and U.S. Computer Emergency Readiness Team (US-CERT) or Financial Services-Information Sharing and Analysis Center (FS-ISAC) alerts. The vulnerabilities may affect unpatched and unsupported operating system versions. Take a risk-based approach when offering MFS to customers using unpatched and unsupported operating system versions and recommend to customers that they upgrade to more secure software, operating systems, and devices when appropriate.
- Periodically testing the functionality of MFS applications with other integrated mobile applications and services.

#### ***AppE.5.b(iv) Mobile Payments Risk Mitigation***

Mitigating controls in mobile payments should include discussions between the financial institution and its mobile payments provider to identify and minimize potential risk factors. Financial institution management should work with mobile-payments platform developers to encourage the use of the following:

- Traffic filtering to help prevent or minimize denial-of-service attacks.<sup>28</sup>
- Trusted platform modules.<sup>29</sup>
- Secure telecommunications protocols (e.g., secure sockets layer/transport layer security [SSL/TLS]).

---

<sup>27</sup> A sandbox is a restricted, controlled execution environment that prevents potentially malicious software, such as malicious mobile code, from accessing any system resources except those for which the software is authorized.

<sup>28</sup> The goal of a denial-of-service attack is to restrict the availability of services or systems. If the institution can effectively filter traffic to disallow unknown or potentially malicious traffic, this can support the institution’s larger denial-of-service planning.

<sup>29</sup> The trusted platform module is an international standard for a secure crypto processor that is a dedicated microprocessor designed to secure hardware by integrating cryptographic keys into devices.

- Tokenization<sup>30</sup> to limit the transmission of account information.
- Encryption to minimize the opportunity for the interception of traffic.
- Anti-malware software.
- Authentication controls of both the user and application.
- Encryption of personal information stored on the mobile device.

### **AppE.5.c Compliance Risk Mitigation**

Institution management and system designers should consult with compliance staff to minimize compliance risks when developing and implementing MFS. Financial institution management should reassess its current mobile service offerings regularly and, in conjunction with appropriate compliance and legal staff, examine applicable laws and regulations, including those for consumer protection, to determine which may apply to their specific mobile financial service offerings. The compliance officer should take the following steps:

- Determine whether applicable disclosure requirements are fully accessible on the mobile device.
- Review the institution's existing compliance management system and ability to make appropriate modifications to policies and procedures to address the products, services, and operating features of the MFS technology.
- Monitor for any legal and regulatory changes that may be applicable to MFS on an ongoing basis.
- Train institution staff regarding compliance implications of MFS.

### **AppE.5.d Reputation Risk Mitigation**

To protect its brand reputation, management should adopt appropriate and effective controls over customer information accessed, transmitted, or stored by the MFS to minimize or prevent disclosure of personal information and the potential for fraudulent transactions. Management should implement such controls whether it is providing the MFS directly or through a third party.

## **AppE.6 Monitoring and Reporting**

Financial institution management should have appropriate performance monitoring systems for assessing whether the product or service is meeting operational expectations. Such systems should do the following:

- Include limits on the level of acceptable risk exposure that management and the board are willing to assume.
- Identify specific objectives and performance criteria, including quantitative benchmarks for evaluating success of the product or service.
- Periodically compare actual results with projections and qualitative benchmarks to detect and address adverse trends or concerns in a timely manner.

---

<sup>30</sup> In the context of data security, tokenization is the process of substituting a sensitive data element with a surrogate value, referred to as a token.

- Modify the business plan, when appropriate, based on the performance of the product or service. Such changes may include exiting the activity should actual results fail to achieve projections.

A variety of reports can facilitate management oversight of MFS activities. Management should structure the report content to meet the needs of the various levels of management. Reports should address point-in-time as well as trend activity for both individual customers and mobile channel activities to compare actual trends with the mobile strategy. Reports for new services should emphasize the volume of activity from the onset and report on changes in usage or volume over time. Management should develop reports to document the various demographic and industry sectors served and monitor changes in these areas to determine whether the MFS offered are meeting the institution's strategy or should be refined.

## AppE.7 Mobile Financial Services Work Program

**Objective 1:** *Management effectively responds to issues raised or problems related to MFS.*

1. Review examination documents and financial institution reports for outstanding issues or problems related to MFS. Consider the following:
  - a. Pre-examination planning memos.
  - b. Prior regulatory reports of examination.
  - c. Prior examination work papers.
  - d. Internal and external audit reports, including SSAE 16<sup>31</sup> reports.
  - e. Financial institution's overall risk assessment and strategic plan.
2. Review management's response to audit recommendations on MFS, if any, noted since the prior examination. Consider the following:
  - a. Adequacy and timing of corrective action.
  - b. Resolution of root causes rather than just specific audit deficiencies.
  - c. Existence of any outstanding issues.
  - d. Monitoring systems used to track the implementation of recommendations on an ongoing basis.

**Objective 2:** *Financial institution management incorporates (or plans to incorporate) its plan for implementing MFS into its strategic planning process.*

1. Determine whether financial institution management has an MFS strategy to identify the types of MFS that management plans to offer.

---

<sup>31</sup> Statement on Standards for Attestation Engagements (SSAE) No. 16 is a type of audit report of controls at a service organization.

2. Describe the MFS that the financial institution offers. Determine whether the institution offers or implements MFS through one or more of the following technologies:
  - a. SMS.
  - b. Mobile-enabled Web sites or browsers.
  - c. Mobile applications.
  - d. Technologies that enable mobile payments.

**Objective 3: *Financial institution management identifies the risks associated with offering MFS.***

1. After the MFS strategy is complete, determine whether the institution developed an effective risk assessment process for the MFS offerings. Verify whether management incorporates the results of the risk assessment into a process to periodically review and update the strategy.
2. Review whether the risk identification process includes risks associated with MFS, particularly in the areas of strategic, operational, regulatory, and reputation risks.
3. With respect to strategic risk, determine whether management identified the risks associated with the decision to offer MFS and whether that is consistent with the strategic vision, goals, and risk appetite of the institution.
4. Determine whether management considered and identified operational risks associated with MFS, including risks involved with the following:
  - a. Transaction initiation and completion.
  - b. Authentication and authorization.
  - c. Technology used for MFS.
  - d. Mobile devices.
  - e. Method of communication between the device and the terminal accepting payment.
  - f. Authentication and security of access points.
  - g. Fraud tools and techniques.
  - h. Current and emerging threats to mobile applications, weaknesses in mobile application security, and prevalence of mobile devices, common operating systems, and downloadable applications.
5. Determine whether management also considered the implications of operational risks specific to technologies used to implement MFS. Specifically, review whether management appropriately identified the differing risks related to the following technologies:
  - a. **SMS:** Include the lack of security through unencrypted text messages; SMS spoofing; and fraudulent text messages (phishing).
  - b. **Mobile-enabled Web sites:** Include vulnerabilities with Internet banking (hardware, operating system, and security limitations); malicious messages through Web-based attack vectors; limitations on anti-phishing and anti-XSS capabilities; malicious attacks

- through unvalidated redirects and forwards; user constraints on recognizing phished or forged sites; and limitations on visual security cues.
- c. **Mobile application:** Include application vulnerabilities (e.g., unpatched and outdated applications); malware; ability to jailbreak or root devices; use of unapproved application stores; weak storage controls over confidential information on devices; and inappropriate access to back-end databases.
  - d. **Mobile payments:** Include loss or theft of mobile devices leading to unauthorized payments, funds transfers, and credit card purchases; interception of NFC communications; and weak security controls in the payment provisioning process.
6. With respect to compliance risk, determine whether management identified the applicable risks related to MFS. Review whether management understands that the consumer laws, regulations, and supervisory guidance that apply to a given financial product or payment method generally apply regardless of the technology used. Additionally, determine whether management identified risks associated with the use of nontraditional third-party service providers often found in the innovation and development sphere of MFS.
  7. With respect to reputation risk, determine whether management identified the following:
    - a. Potential reputation risk that may arise from providing MFS, including issues related to privacy and data security.
    - b. Risks associated with the decision to outsource the development and maintenance of mobile products and the effect of third parties on the institution's risk profile.

***Objective 4: Financial institution management appropriately and effectively measures risks associated with MFS and determines the likelihood and impact of those risks.***

1. Determine whether management effectively measures risks and determines the likelihood and impact of those risks.
2. Determine whether management effectively prioritizes measured risks.
3. Determine the effectiveness of the frequency of the measurement process.

***Objective 5: Financial institution management effectively identifies and implements controls to mitigate identified and prioritized risks associated with the MFS offering.***

1. Determine whether management incorporates mobile risks into the overall risk management process.
2. Determine whether management implements policies and procedures for the MFS offering.
3. Determine whether management puts in place appropriate internal controls to ensure security and confidentiality of MFS.

4. Determine whether management implements controls to mitigate all applicable categories of risks related to MFS, including strategic, operational, compliance, and reputation risk.
  - a. **Strategic risk mitigation:** Review whether management incorporates its decisions to provide MFS into its strategic planning process.
  - b. **Operational risk mitigation:** Review whether management controls include the following: risk management; transaction monitoring and geolocation tools; fraud prevention, detection, and response programs; additional controls (e.g., stronger authentication<sup>32</sup> and encryption); authentication and authorization processes (e.g., processes to enroll customers and devices in the mobile channel); application development and distribution controls (e.g., process for approving and submitting mobile application code to distribution partners); application security controls (including strategy to deactivate older application versions); contracts and agreements; customer awareness processes; and logging and monitoring processes. Specifically, review the controls that management has in place over the technologies employed for MFS, including the following:
    - SMS technology.
    - Mobile-enabled Web sites.
    - Mobile application.
    - Mobile payments.
  - c. **Compliance risk mitigation:** Review whether management consults with compliance staff, reassessing current mobile service offerings regularly and examining for compliance with applicable laws and regulations.
  - d. **Reputation risk mitigation:** Review whether management includes the use of controls to minimize or prevent disclosure of personal information and the potential for fraudulent transactions. Also, review management's mitigation of risks associated with the use of a third party, if applicable.
5. Determine whether management has appropriate and independent testing of controls for effectiveness.

**Objective 6:** *Financial institution management maintains effective oversight of MFS activities. Management maintains appropriate reporting for various levels of management to support that oversight.*

1. Review the monitoring process to determine whether the institution has appropriate performance monitoring systems to allow management to assess whether the product or service is meeting operational expectations. Determine whether the systems include the following features:
  - a. Limits on the level of acceptable risk exposure that management and the board are willing to assume.
  - b. Specific objectives and performance criteria to evaluate success of the product or service.

---

<sup>32</sup> A review should include the financial institution's consideration of expectations set forth in appropriate supervisory guidance (e.g., authentication guidance in footnote 20 of this appendix).

- c. Ability to produce reports that periodically compare actual results with projections and qualitative benchmarks that provide trend information.
  - d. Ability to produce reports that provide data, which would trigger changes in the business plan, as appropriate.
- 2. Determine whether the institution's reporting process describes the following:
  - a. MFS activities.
  - b. Information to meet the needs of the various levels of management.
  - c. Trends, volumes, and changes in activity over time.
  - d. Statistics on demographics and locations served to evaluate whether the institution is meeting its strategy.

***Objective 7: Discuss corrective action and communicate findings.***

- 1. Review preliminary conclusions with the examiner-in-charge (EIC) regarding the following:
  - a. Violations of laws and regulations.
  - b. Significant issues warranting inclusion as matters requiring attention or recommendations in the report of examination.
  - c. Proposed URSIT<sup>33</sup> management component rating and the potential impact of the conclusion on composite or other component information technology ratings.
  - d. Potential impact of the conclusions on the institution's risk assessment.
- 2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
- 3. Document conclusions in a memorandum to the EIC that provides report-ready comments for all relevant sections of the report of examination and guidance to future examiners.
- 4. Organize work papers to ensure clear support for significant findings by examination objective.

---

<sup>33</sup> Uniform Rating System for Information Technology.